

Security 개요 및 환경설정

# 수업차시	1
# 페이지수	6

01. Security 개요

01-01. Security

01-01-01. Security란?

- spring Security는 스프링 기반 애플리케이션의 보안(인증과 권한, 인가 등)을 담당하는 스프링 프레임워크이다.
- Security는 인증과 권한에 대한 부분을 Filter의 흐름에 따라서 처리를 하게 되며 보안과 관련된 옵션을 체계적으로 제공해주기 때문에 개발자가 일일이 보안과 관련된 로직을 작성하지 않아도 되는 장점을 가지고 있다.
- 용어 정의
 1. Principal : 주체
 - a. 사용자, 디바이스, 시스템 등의 행위를 하는 주체를 의미
 2. Secured Resource : 보안이 적용되는 리소스
 - a. 일반적으로 메서드를 통해 보호가 된다.
 3. Authentication : 인증
 - a. Principal이 믿을 수 있는지 파악하는 것으로 일반적으로 id/password를 검사하게 된다.
 4. Authorization : 권한
 - a. 인증이 완료된 principal이 어떤 행위를 할 권한이 있는지 확인한다.
 - b. ROLE_ADMIN, ROLE_GUEST, ROLE_MEMBER의 role에 기반해서 접근이 가능하다.

01-01-02. Security 기능

1. 인증 및 접근 제어

사용자의 인증과 접근 제어를 처리하여 인증되지 않는 액세스를 방지한다. 사용자의 자격 증명을 확인하고 권한 부여 및 접근 권한 검사를 수행하여 인가된 사용자만 보호된 리소스에 액세스가 가능하다.

2. CSRF(Cross-Site-Request Forgery) 방어

csrf 공격을 방지하기 위해 요청에 csrf 토큰을 추가하고, 이를 사용하여 유효한 요청인지 검증을 하게된다. 이를 통해 악성 사용자의 요청 위조를 방지할 수 있다.

3. XSS(Cross-Site Scripting) 방어 : XSS 공격을 방지하기 위해 출력 데이터의 이스케이프 처리를 제공하고 있으며 이를 통해 악성 스크립트가 삽입되는 것을 방지하고 사용자의 브라우저에서 안전하게 실행을 보장한다.

4. 세션 관리 : Spring Security는 세션 관리를 통해 세션 하이재킹 및 세션 고정 공격을 방지한다. 적절한 세션 id 생성, 세션 유효성 검사, 세션 제한 시간 설정 등의 기능을 제공하여 세션의 안전성을 강화한다.

5. 보안 헤더 설정 : Spring Security는 보안 헤더를 설정하여 다양한 보안 취약점을 방지한다. Content Security Policy (CSP), X-Content-Type-Options, X-XSS-Protection 등의 헤더를 설정하여 악성 스크립트 실행, mime 타입 스니핑을 방지한다.

6. 로그인 실패 및 계정 잠금 : Spring Security는 로그인 실패 횟수 제한, 계정 잠금 등의 기능을 제공하여 무차별 대입 공격 및 계정 탈취를 방지한다.

7. 보안 취약점 패치 : 보안 취약점에 대한 업데이트와 패치를 지속적으로 제공하여 애플리케이션의 보안을 유지하고 개선한다.
취약점에 대한 경고 및 권장 사항을 제공하여 개발자가 적절한 조치를 취할 수 있도록 한다.

01-01-03. 웹 해킹 종류

- CSRF (Cross-Site Request Forgery)

악의적인 사용자가 피해자의 인증된 세션을 이용하여 비정상적인 요청을 실행하는 공격 형태이다.

공격자는 사용자가 이미 인증된 세션을 가지고 있을 때, 피해자가 의도하지 않은 동작을 수행하도록 요청을 위조한다.

- 공격 흐름

1. 피해자가 악의적인 웹사이트 방문
2. 악의적인 웹사이트는 피해자의 브라우저에 실제로 수행되어야 하는 요청에 위조하여 피해자 사이트로 전송한다.
3. 피해자의 브라우저는 위조된 요청을 실행하고, 이때 피해자의 세션 인증 정보가 함께 전송된다.
4. 서버는 피해자의 세션 인증 정보를 확인하여 해당 요청을 처리하게 되어 악의적인 동작을 실행한다.

- Security의 CSRF 공격 방지를 위한 기능

1. CSRF 토큰 : CSRF 토큰을 포함해 위조된 요청인지 확인한다. 서버는 요청을 처리하기 전에 토큰의 일치 여부를 확인하여, 일치하지 않는 경우 요청을 거부
2. CSRF 헤더 : X-CSRF-Token 이라는 이름의 헤더를 요청에 추가하여 CSRF 공격을 방지한다. 클라이언트는 서버에서 받은 토큰을 헤더에 포함해 요청 시 전송하며 서버는 이를 확인하여 변조를 확인
3. CSRF 보호 설정 : CSRF 보호 설정을 활성화할 수 있으며 이를 통해 기본적인 CSRF 보호 기능을 제공하여, 토큰 생성, 토큰 저장소, 토큰 전송 방식 등을 구성할 수 있다.

- XSS

SQL INJECTION과 함께 웹 상에서 가장 기초적인 취약점 공격 방법의 일종으로, 악의적인 사용자가 공격하려는 사이트에 스크립트를 넣는 기법을 말하며

공격에 성공하면 사이트에 접속한 사용자는 삽입된 코드를 실행하게 되어 의도하지 않은 행동을 수행하게 되거나 쿠키 및 세션 등 민감한 정보를 탈취 당하게 된다.

크로스 사이트 스크립팅은 자바스크립트를 사용하여 공격하는 경우가 많으며 공격 방법이 단순하고 가장 기초적이거나 많은 웹사이트가 xss에 대한 방어 조치를 하지 않아

공격받는 경우가 많으며 여러 사용자가 접근할 수 있는 게시판 등에 코드를 삽입하는 경우가 많으며 때에 따라서는 메일과 같은 매체를 통해서 전파된다.

공격 방법에 따라 명칭이 분류되며 다음과 같은 기법이 있다.

- Stored Xss

저장형 xss 공격은 보안이 취약한 서버에 악의적인 사용자가 악성 스크립트를 저장함으로써 발생하며 비정상적인 방법이 아닌 서버에서 제공하는

게시판, 사용자 프로필에 악의적으로 동작하는 스크립트가 그대로 저장된 후 클라이언트의 브라우저로 전달되어 문제가 발생하게 된다.

- Reflected Xss

요청 메시지에 입력된 스크립트 코드가 즉시 응답 메시지를 통해 출력되는 취약점으로 입력된 스크립트가 반사되는 것처럼 동작하기 때문에 붙은 이름이다.

- 세션 하이재킹

세션 하이재킹 또는 세션 도용이라 불리는 공격은 공격자가 컴퓨터 네트워크에서 사용자의 세션을 장악하려고 시도하는 보안 공격이다. 이 공격에서 공격자는 인증 및 세션 관리에 사용되는

세션 토큰 또는 세션 식별자를 가로채고 조작하여 사용자 세션에 대한 무단 액세스 권한을 얻는 것을 목표로 한다.

- 공격 흐름

- 사용자 세션 생성됨

사용자가 웹 애플리케이션이나 서비스에 로그인하면 서버에 세션이 생성된다.

서버는 고유한 세션 식별자(세션 쿠키)를 클라이언트 측에 저장되는 사용자 세션에 할당하게 된다.

- 세션 토큰 교환

사용자의 브라우저와 서버 간의 후속 상호 작용 중에 클라이언트는 요청을 인증하고 서버에 올바른 세션과 연결하기 위해 http 요청에 세션 식별자를 쿠키에 포함한다.

- 세션 가로채기

공격자는 네트워크 트래픽 스니핑, 맬웨어 사용 또는 중간자 공격 실행과 같은 네트워크의 취약성을 악용하여 세션 식별자를 가로채게 된다.

- 세션 하이재킹

공격자가 세션 식별자를 획득하면 이를 사용하여 사용자 세션을 가장 할 수 있으며 세션 식별자를 직접 사용하거나 자신의 브라우저 또는 스크립트에 삽입하여 대상 세션에 대한 무단 액세스를 얻을 수 있다.

- 하이재킹된 세션 악용

공격자는 하이재킹된 세션을 제어하여 손상된 세션과 관련된 권한 및 기능에 따라 다양한 악의적인 작업을 수행할 수 있다.

여기에는 민감한 정보 도용, 무단 거래 수행 또는 사용자 계정 설정 조작이 포함됨

- 세션 고정공격

공격자가 미리 결정된 세션 식별자 또는 세션 토큰을 사용하도록 사용자를 속이는 보안 공격 유형이다.

이 공격은 사용자가 공격자가 제어하는 세션으로 인증하도록 강제하여 사용자의 브라우저와 웹 응용 프로그램 간의 신뢰를 악용하는 것이다.

- 공격 흐름

- 초기 세션 식별자

공격자는 세션 식별자 또는 토큰을 생성하고 사용자가 이를 인증에 사용하도록 속인다.

- 사용자 인증

사용자가 악성 링크를 클릭하여 웹 애플리케이션 또는 서비스에 액세스한다.

응용 프로그램은 공격자가 제공한 세션 식별자를 합법적인 세션으로 받아들인다.

- 세션 하이재킹

사용자가 인증되면 공격자는 고정된 세션 식별자를 악용하여 사용자 세션에 대한 무단 액세스 권한을 얻을 수 있다. 네트워크 트래픽을 가로채거나 XSS 취약점을 활용하는 등 다양한 방법을 사용하여 세션을 하이재킹할 수 있다.

- 하이재킹된 세션 악용

공격자는 세션을 제어하여 사용자를 대신해 악의적인 활동을 수행하게 됨

- Content Security Policy (CSP)

콘텐츠 보안 정책은 xss 및 데이터 주입과 같은 다양한 유형의 공격을 완화하고 보호하기 위한 웹 애플리케이션에서 구현하는 보안 메커니즘으로

csp는 웹 개발자가 웹 페이지를 로드하고 실행할 수 있는 콘텐츠를 지정하는 일련의 규칙 또는 정책을 정의하고 시행할 수 있도록 해주는 http 헤더이다.

- X-Content-Type-Options

브라우저 응답의 콘텐츠 유형을 해석하는 방법을 제어하기 위해 웹 서버에서 사용할 수 있는 http 응답 헤더이다.

브라우저가 선언된 콘텐츠 유형에 의존하는 대신 응답 콘텐츠 유형을 추측하고자 할 때 발생하는 mime 스니핑 공격에서 보호하는 데 도움이 되는 보안 헤더이다.

1. "nosniff": 이 지시문이 "nosniff" 값이 있는 헤더에 포함된 경우(예: "X-Content-Type-Options: nosniff") 브라우저가 선언된 콘텐츠 유형을 엄격하게 준수하도록 지시합니다. 응답하고 콘텐츠 유형 스니핑을 수행하지 않습니다. 서버가 콘텐츠 유형을 지정하면 브라우저는 이를 신뢰할 수 있는 값으로 취급하고 콘텐츠 유형을 추측하려고 시도하지 않습니다.

2. "none": 이 지시문은 더 이상 사용되지 않으며 사용해서는 안 됩니다. 이전에는 MIME 스니핑을 완전히 비활성화하는 데 사용되었습니다. 그러나 이제 동일한 효과를 얻기 위해 "nosniff" 지시어를 사용하는 것이 좋습니다.

- X-XSS-Protection

XSS-Protection은 최신 웹 브라우저에 제공하는 내장 xss 보호 메커니즘을 활성화 또는 비활성화하기 위해 웹 서버에서 사용할 수 있는 HTTP 응답 헤더이다.

XSS 공격은 공격자가 악의적인 스크립트를 웹 페이지에 삽입한 뒤 다음 다른 사용자의 브라우저 컨텍스트에 실행되어 잠재적으로 무단 액세스 또는 데이터 도난으로 이어질 때 발생한다.

X-XSS-Protection 헤더를 통해 웹 개발자는 브라우저의 XSS 보호 기능 동작을 제어할 수 있으며 다음과 같은 방식을 사용한다.

1. "0": 브라우저에서 XSS 보호 기능을 비활성화합니다. 브라우저는 XSS 공격을 감지하거나 차단하려고 시도하지 않습니다.
2. "1": 브라우저에서 XSS 보호 기능을 활성화합니다. 브라우저가 잠재적인 XSS 공격을 감지하면 악성 스크립트를 차단하고 페이지를 실행하지 않고 렌더링하려고 시도합니다.
3. "1; mode=block": 브라우저에서 XSS 보호 기능을 활성화하고 잠재적인 XSS 공격이 감지되면 페이지가 차단되도록 합니다. 이 지시문은 더 엄격하며 공격이 의심되는 경우 페이지가 렌더링 되지 않도록 합니다.

- 스니핑

컴퓨터 네트워크 및 보안의 맥락에서 스니핑은 분석 또는 승인되지 않는 목적을 위해 네트워크 트래픽을 가로채고 캡처하는 행위를 이야기한다.

여기서 데이터 패킹이 네트워크를 통과할 때 캡처하여 공격자나 승인된 엔티티가 패킷의 내용을 검사 할 수 있도록 한다.

네트워크 스피닝은 이를 수행하는 개인의 상황과 의도에 따라 합법적일 수 있고 악의적일 수 있다.

- 스니핑 종류

- 패킷 스니핑

개별 네트워크 패킷 캡처와 검사가 포함되며 네트워크 인터페이스를 무차별 모드로 설정하면 스니퍼 도구 또는 소프트웨어가 네트워크의 다른 장치로 향하는 패킷을 캡처하여 사용자가 포함된 데이터를 분석

- 이더넷 스니핑

이더넷 스니핑은 특히 이더넷 네트워크를 통한 데이터 전송의 기본 단위인 이더넷 프레임 캡처 및 분석에 중점을 둔다. 네트워크 모니터링 또는 보안 분석에 활용

- 무선 스니핑

wi-fi 스니핑이라고 하는 무선 스니핑에는 무선 네트워크 트래픽 캡처 및 분석이 포함된다. 올바른 도구와 기능을 사용하면 공격자 또는 보안 전문가가 장치 간의 무선 통신을 가로채 무선으로 전송되는 패킷을 캡처한다.

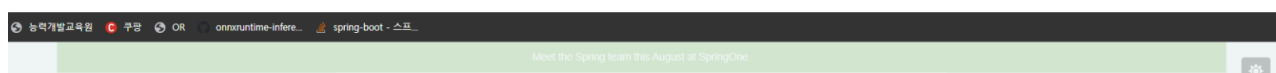
- 네트워크 트래픽

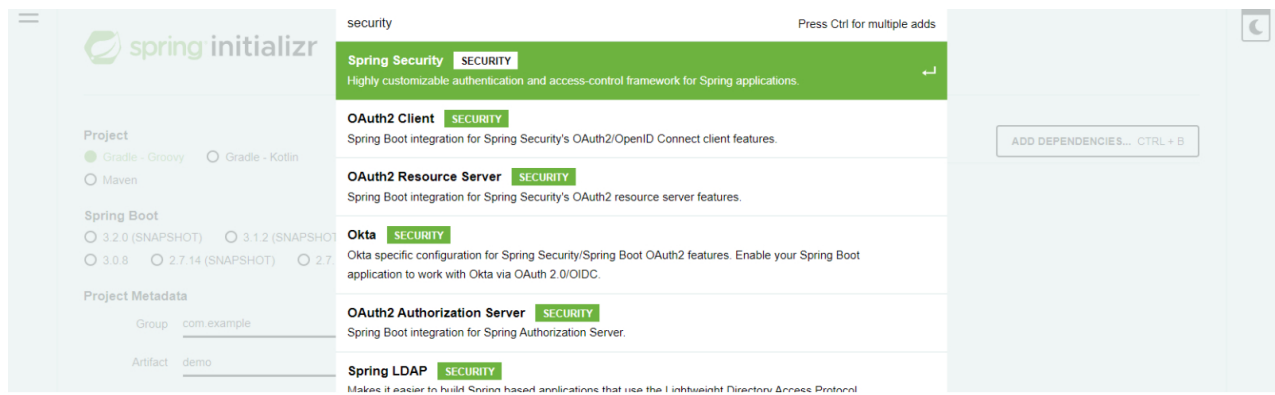
네트워크 통신 패턴, 흐름 및 콘텐츠 모니터링 및 검사가 포함된다. 패턴을 분석하고 이상을 식별하여 보안 전문가가 네트워크 내에서 잠재적인 위협이나 비정상적인 동작을 탐지한다.

01-02. SprintSecurity 환경 설정

01-02-01. SpringSecurity

- 스프링 시큐리티는 JDK 8 이상의 버전을 필요로 한다.
- Springboot 기준으로 boot version에 맞춰서 지원이 되는 버전이 다르기 때문에 다음과 같은 방식으로 지원되는 라이브러리를 사용하는 것이 좋다.





- 다음과 같이 의존성이 추가된다.

```
dependencies {  
    implementation 'org.springframework.boot:spring-boot-starter-security'  
    implementation 'org.springframework.boot:spring-boot-starter-thymeleaf'  
    implementation 'org.springframework.boot:spring-boot-starter-web'  
    implementation 'org.thymeleaf.extras:thymeleaf-extras-springsecurity5'  
    // https://mvnrepository.com/artifact/org.bouncycastle/bcprov-jdk15on  
    implementation group: 'org.bouncycastle', name: 'bcprov-jdk15on', version: '1.70'  
  
    developmentOnly 'org.springframework.boot:spring-boot-devtools'  
    testImplementation 'org.springframework.boot:spring-boot-starter-test'  
    testImplementation 'org.springframework.security:spring-security-test'  
}
```